

LAPORAN PENILAIAN KEAMANAN

VM RickdiculouslyEasy – Boot-to-Root CTF

Reconnaissance • Scanning • Enumeration • Privilege Escalation

Penulis	Mark Delano Rembet
Platform	VulnHub – RickdiculouslyEasy
Total Flag	9 Flags (130 Points)
Tujuan	Akses Root + Pengumpulan Flag Penuh

Dokumen ini adalah laporan penilaian keamanan profesional dari mesin virtual RickdiculouslyEasy. Laporan ini ditujukan untuk penggunaan portofolio dan publikasi di GitHub.

DAFTAR ISI

1. Pendahuluan
2. Alat yang Digunakan
3. Metodologi & Langkah Eksekusi
4. Enumerasi & Eksploitasi
5. Eskalasi Hak Akses
6. Pengumpulan Flag (Detail)
7. Ringkasan Hasil
8. Kesimpulan & Analisis
9. Rekomendasi Keamanan

PENDAHULUAN

Deskripsi Proyek

Penilaian keamanan ini dilakukan terhadap mesin virtual RickdiculouslyEasy yang tersedia di platform VulnHub. VM ini adalah CTF boot-to-root tingkat pemula dengan tema Rick and Morty. Ini berbasis pada Fedora Server dan dibuat menggunakan VirtualBox (juga kompatibel dengan VMware).

Tujuan Proyek

Tujuan utamanya adalah untuk mengeksploitasi kerentanan yang ada pada sistem target dan mengumpulkan semua flag yang tersebar di berbagai lokasi (spanduk layanan, file FTP, halaman web, kode sumber, dan direktori sistem setelah mendapatkan akses). Setiap flag memiliki nilai poinnya sendiri, dengan total 130 poin. Selain mengumpulkan semua flag, penilaian ini bertujuan untuk mendapatkan akses root pada sistem.

Proses pengujian mencakup pengintaian, enumerasi, eksploitasi, dan eskalasi hak akses, dengan dokumentasi lengkap untuk setiap langkah dan temuan.

Spesifikasi VM

Komponen	Spesifikasi
Sistem Operasi	Linux (Fedora Server)
CPU	1 GHz single or dual-core processor
RAM	1 GB minimum
Penyimpanan	10 GB minimum
Jaringan	DHCP (Bridge Adapter)
Tingkat Kesulitan	Beginner (Boot-to-Root CTF)

ALAT YANG DIGUNAKAN

Alat-alat berikut digunakan sesuai dengan metodologi pengujian penetrasi standar:
Pengintaian → Enumerasi → Eksploitasi → Eskalasi Hak Akses.

Tool	Purpose
Nmap	Pemindaian port, deteksi layanan & versi, OS fingerprinting
Netcat (nc)	Menghubungkan ke layanan non-standar / bind shell
FTP Client	Menjelajahi layanan FTP (login anonim)

Dirsearch / Gobuster	Brute-force direktori pada server web (port 80)
Browser	Mengakses halaman web (port 80 & 9090) dan melihat kode sumber
Hydra	Brute-force kata sandi menggunakan daftar kata (wordlist) kustom
Python 3	Membuat daftar kata kustom berdasarkan petunjuk kata sandi
SSH Client	Masuk ke sistem dengan kredensial yang ditemukan
Strings / Unzip	Analisis file (steganografi & arsip yang dilindungi)
SCP	Eksfiltrasi data dari target ke mesin lokal

METODOLOGI & LANGKAH EKSEKUSI

Pengintaian – Pemindaian Port dengan Nmap

Langkah pertama adalah pemindaian port penuh dari target untuk mengidentifikasi host aktif, port terbuka, layanan, dan versi. Perintah yang digunakan:

```
sudo nmap -sC -p- -A <TARGET_IP>
```

Pemindaian mengungkapkan beberapa port terbuka yang menjadi titik masuk utama:

Port	Service	Status	Notes
21	FTP (vsftpd 3.0.3)	Terbuka	Login anonim diizinkan
22	SSH (tertutup)	Disaring	Port standar tertutup
80	HTTP (Apache 2.4.27)	Terbuka	Server web + daftar direktori
9090	Cockpit / HTTPS	Terbuka	Halaman admin terbuka tanpa autentikasi
13337	Tidak diketahui	Terbuka	Spanduk langsung menampilkan Flag 1
22222	OpenSSH 7.5	Terbuka	SSH pada port non-standar
60000	Tidak diketahui / Bind Shell	Terbuka	Akses tanpa autentikasi



Enumerasi & Eksploitasi

Menggunakan Hydra dengan daftar kata kredensial default, login sebagai anonim berhasil dilakukan. File FLAG.txt berhasil diunduh (Pengungkapan Informasi).

[illegible]

Enumerasi Direktori Web

MDRembet



Dari robots.txt, jalur /cgi-bin/tracertool.cgi ditemukan. Input formulir tidak divalidasi, memungkinkan injeksi perintah:

Output tersebut mengungkapkan tiga pengguna sistem: RickSanchez, Morty, dan Summer. Kata sandi Summer ditemukan di kode sumber HTML (winter).



Berhasil login menggunakan Summer:winter pada port 22222. Dari pijakan ini, direktori home pengguna lain dieksplorasi dan data dieksfiltrasi.



Port 60000 menyediakan shell tanpa autentikasi. Flag 6 segera ditemukan di sini.

MDRembet

```
(kali@kali)-[~/Documents/zeus/ssh/ricks]
$ nc 10.248.153.213 60000
Welcome to Ricks half baked reverse shell...
# ls
FLAG.txt
# cat FLAG.txt
FLAG{Flip the pickle Morty!} - 10 Points
#
```

Gambar 6 – Netcat bind shell pada port 60000 mengungkapkan Flag 6

Eskalasi Hak Akses

Setelah mendapatkan akses sebagai Summer, pergerakan lateral (lateral movement) dilakukan ke pengguna Morty (journal.txt.zip + Safe_Password.jpg). Kata sandi zip dipulihkan menggunakan strings (Meeseek). Flag 7 dan petunjuk untuk biner safe (safe binary) ditemukan.

Menjalankan biner safe dengan parameter 131333 menghasilkan Flag 8 dan petunjuk kata sandi untuk RickSanchez. Daftar kata kustom dibuat dengan Python berdasarkan pola: 1 huruf besar + 1 angka + kata dari nama band "The Flesh Curtains".

Hydra berhasil memulihkan kata sandi P7Curtains. Setelah login sebagai RickSanchez, eskalasi hak akses dicapai melalui sudo su (kesalahan konfigurasi) menjadi root. Flag terakhir (Ionic Defibrillator – 30 poin) ditemukan di /root.

```
(kali@kali)-[/usr/share/wordlists]
$ ssh RickSanchez@10.248.153.213 -p 22222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
RickSanchez@10.248.153.213's password:
Permission denied, please try again.
RickSanchez@10.248.153.213's password:
Last failed login: Wed Aug 5 02:40:26 AEST 2026 from 10.248.153.204 on ssh:notty
There was 1 failed login attempt since the last successful login.
Last login: Wed Aug 5 01:56:53 2026 from 10.248.153.204
[RickSanchez@localhost ~]$ whoami
RickSanchez
[RickSanchez@localhost ~]$ sudo su
[sudo] password for RickSanchez:
Sorry, try again.
[sudo] password for RickSanchez:
Sorry, try again.
[sudo] password for RickSanchez:
sudo: 3 incorrect password attempts
[RickSanchez@localhost ~]$ whoami
RickSanchez
[RickSanchez@localhost ~]$ sudo su
[sudo] password for RickSanchez:
root@localhost RickSanchez# whoami
root
[root@localhost RickSanchez#
```

Gambar 7 – Eskalasi hak akses ke root dan Flag 9 terakhir

PENGUMPULAN FLAG (DETAIL)

FLAG 1. TheyFoundMyBackDoorMorty – 10 Poin

Lokasi: Spanduk pada port 13337 (Nmap)

Metode: Enumerasi layanan dengan Nmap. Flag muncul secara langsung pada spanduk layanan.

FLAG 2. Whoa this is unexpected – 10 Poin

Lokasi: /var/ftp (FLAG.txt)

Metode: Login FTP anonim (setelah brute-force / kredensial default). File diunduh dengan GET.

FLAG 3. Yeah d- just don't do it. – 10 Poin

Lokasi: /passwords/FLAG.txt (Web)

Metode: Brute-force direktori (Dirsearch) menemukan /passwords/. Daftar direktori diaktifkan.

FLAG 4. Get off the high road Summer! – 10 Poin

Lokasi: /home/Summer/FLAG.txt

Metode: Injeksi perintah pada tracertool.cgi → enumerasi pengguna → kata sandi 'winter' dari sumber HTML → SSH sebagai Summer.

FLAG 5. There is no Zeus, in your face — 10 Poin

Lokasi: <https://TARGET:9090> (Cockpit)

Metode: Akses langsung ke halaman indeks pada port 9090 tanpa autentikasi.

FLAG 6. Flip the pickle Morty! — 10 Poin

Lokasi: Port 60000 (bind shell)

Metode: Netcat ke port 60000 → shell tanpa autentikasi → cat FLAG.txt.

FLAG 7. 131333 — 20 Poin

Lokasi: /home/Morty/journal.txt

Metode: SCP file dari home Morty → strings pada Safe_Password.jpg → kata sandi 'Meeseek' → unzip journal.txt.zip.

FLAG 8. And Awwwaaaaayyyy we Go! — 20 Poin

Lokasi: Biner safe (RICKS_SAFE)

Metode: Eksekusi ./safe 131333 (parameter dari Flag 7). Output berisi flag + petunjuk kata sandi untuk Rick.

FLAG 9. Ionic Defibrillator — 30 Poin

Lokasi: /root/FLAG.txt

Metode: Daftar kata Python kustom → Hydra SSH sebagai RickSanchez (P7Curtains) → sudo su → akses /root.

RINGKASAN HASIL

Flag	Points	Primary Location	Main Tools
1. TheyFoundMyBackDoorMorty	10	Spanduk Nmap :13337	Nmap
2. Whoa this is unexpected	10	/var/ftp	Hydra, FTP
3. Yeah d- just don't do it.	10	/passwords/	Dirsearch
4. Get off the high road Summer!	10	/home/Summer	Injeksi Cmd, SSH
5. There is no Zeus, in your face	10	Port 9090	Browser
6. Flip the pickle Morty!	10	Port 60000	Netcat
7. 131333	20	/home/Morty	SCP, strings, unzip
8. And Awwwwaaaaayyyy we Go!	20	RICKS_SAFE/safe	SSH, biner
9. Ionic Defibrillator	30	/root	Python, Hydra, sudo
TOTAL	130		

Status: Semua 9 flag berhasil dikumpulkan (130/130 poin). Akses root diperoleh melalui eskalasi hak akses.

```
(kali@kali) - [~/Documents/zeus]
** ssh Summer@10.248.153.213 -p 22222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pg.html
Summer@10.248.153.213's password:
Last login: Tue Aug 4 16:01:34 2026 from 10.248.153.204
[Summer@localhost ~]$ ls
FLAG.txt
[Summer@localhost ~]$ cat FLAG.txt
```



```
[Summer@localhost ~]$ get FLAG.txt
-bash: get: command not found
[Summer@localhost ~]$ more FLAG.txt
FLAG{Get off the high road Summer!} - 10 points
```

Gambar 8 – Flag 5 ditampilkan pada antarmuka Cockpit (port 9090)

KESIMPULAN & ANALISIS

Analisis Efektivitas Alat

Nmap – Alat pengintaian standar. Opsi -sC -p- -A memberikan gambaran lengkap tentang port, layanan, versi, dan bahkan flag langsung di sebuah spanduk.

Hydra – Sangat efektif untuk brute-force. Mendukung multi-threading dan banyak protokol. Daftar kata kustom kecil (dibuat dengan Python) membuat brute-force SSH sangat efisien.

Dirsearch – Dengan cepat menemukan direktori tersembunyi dan mendukung pemindaian rekursif.

Netcat – Ringan dan fleksibel untuk layanan kustom/tidak diketahui (bind shell).

Strings + Unzip + Python – Kombinasi ideal untuk analisis file, steganografi sederhana, dan pembuatan daftar kata kustom.

Tantangan dan Solusi Teknis

Category	Challenge	Solution
Pengintaian	Port & layanan tidak diketahui	Pemindaian penuh Nmap (-p- -A)
Autentikasi	Kata sandi tidak diketahui / kompleks	Hydra + Daftar Kata Kustom
Eksplorasi Web	Direktori tersembunyi & Injeksi Perintah	Dirsearch + Inspeksi Manual
Pergerakan Lateral	Akses ke pengguna lain	SCP setelah login SSH
Analisis File	Kata sandi tersembunyi dalam file	strings + unzip
Eskalasi Hak Akses	Akses root terbatas	kesalahan konfigurasi sudo

Rekomendasi Keamanan

Berdasarkan temuan, rekomendasi perbaikan berikut dapat diterapkan pada sistem serupa:

1. **Pengungkapan Informasi:** Tutup port yang tidak perlu, nonaktifkan daftar direktori, pindahkan file sensitif keluar dari akar web, dan tambahkan autentikasi atau pembatasan IP. Port 13337 dan 9090 tidak boleh mengekspos data sensitif secara publik.
2. **Layanan Salah Konfigurasi:** Nonaktifkan layanan yang tidak digunakan, ganti FTP dengan SFTP, terapkan autentikasi, batasi akses dengan firewall, dan jalankan layanan dengan pengguna berhak akses rendah. FTP anonim dan bind shell tanpa autentikasi adalah masalah kritis.
3. **Injeksi Perintah OS:** Validasi semua input secara ketat, hindari fungsi berbahaya seperti system() atau exec(), dan jalankan aplikasi dengan hak istimewa minimal (prinsip hak istimewa terkecil).
4. **Autentikasi & Kata Sandi Lemah:** Terapkan kata sandi acak yang kuat, hapus semua petunjuk kata sandi, jangan pernah menyimpan kredensial dalam kode sumber atau file media, dan aktifkan perlindungan brute-force (fail2ban / pembatasan laju).
5. **Kontrol Akses & Eskalasi Hak Akses:** Atur izin direktori home menjadi ketat (chmod 700), audit file sudoers, hapus hak NOPASSWD yang tidak perlu, dan terapkan prinsip hak istimewa

terkecil.

6. **Desain Tidak Aman:** Jangan gunakan nilai yang sudah diketahui sebagai rahasia, terapkan autentikasi kuat, larang penyimpanan kata sandi dalam file media, dan gunakan enkripsi kuat dengan kata sandi kompleks.

Laporan ini ditulis ulang secara profesional untuk tujuan portofolio dan publikasi. Semua langkah dilakukan dalam lingkungan lab yang legal (VulnHub) untuk pendidikan Peretasan Etis (Ethical Hacking).

— Mark Delano Rembet —